

WebShield Security Report

Report ID: WS-12-20260629
Generated: 2026-06-29 15:04:22 UTC
Target: https://accounts.google.com/b/0/AddMailService

Executive Summary

Score	Risk	Findings	Groups	Pages	Duration
0/100	CRITICAL	128	16	32	416s

The website has critical security issues that require immediate attention. There are severe vulnerabilities that could lead to complete system compromise.

Critical	High	Medium	Low	Info
10	29	50	39	0

Priority Triage

Priority	Severity	Finding	Count	First URL
1	CRITICAL	Potential Command Injection in URL Parameter	10	https://accounts.google.com/ServiceLogin?hl=en-GB&continue=https://policies.google.com/terms?gl%3DJM%26hl%3Den-GB
2	HIGH	Cookie 'NID' Missing Secure Flag	1	https://accounts.google.com/TOS?loc=JM&hl=en-US&privacy=true
3	HIGH	Directory Listing Enabled	2	https://accounts.google.com/TOS?loc=JM&hl=en-GB&privacy=true
4	HIGH	Potential XSS Vulnerability in HTML Content	26	https://accounts.google.com
5	MEDIUM	Dynamic Code Execution in Client JavaScript	1	https://accounts.google.com/b/0/AddMailService#inline-script-1
6	MEDIUM	Google or Firebase API Key Exposed in JavaScript	1	https://accounts.google.com/TOS?loc=JM&hl=en-US&privacy=true#inline-script-1
7	MEDIUM	Security-Sensitive Value Uses Math.random	1	https://accounts.google.com/b/0/AddMailService#inline-script-6
8	MEDIUM	Cookie 'NID' Missing SameSite Attribute	1	https://accounts.google.com/TOS?loc=JM&hl=en-US&privacy=true

Category Overview

Category	Instances	Groups	Highest
Vulnerabilities	55	4	CRITICAL
Cookies	2	2	HIGH
Sensitive Data	2	1	HIGH

Category	Instances	Groups	Highest
Security Headers	52	4	MEDIUM
Forms	13	1	MEDIUM
Client Code	4	4	MEDIUM

Grouped Findings

1. [CRITICAL] Potential Command Injection in URL Parameter

10 finding(s), 10 affected URL(s)

Description: URL parameter "continue" contains patterns that may indicate command injection vulnerability.

Evidence: Parameter continue: <https://policies.google.com/terms?gl=JM&hl=en-GB>

Recommendation: Never pass user input directly to system commands.

Affected URLs:

<https://accounts.google.com/ServiceLogin?hl=en-GB&continue=https://policies.google.com/terms?gl%3DJM%26hl%3Den-GB>
<https://accounts.google.com/ServiceLogin?hl=en-US&continue=https://policies.google.com/terms?gl%3DJM%26hl%3Den-US>
<https://accounts.google.com/ServiceLogin?hl=en-US&continue=https://policies.google.com/terms?hl%3Den-US>
<https://accounts.google.com/ServiceLogin?passive=1209600&continue=https://policies.google.com/terms?gl%3DJM%26hl%3Den-GB&followup=https://policies.google.com/terms?gl%3DJM%26hl%3Den-GB&hl=en-GB&ec=GAZAoQQ>
<https://accounts.google.com/ServiceLogin?passive=1209600&continue=https://policies.google.com/terms?gl%3DJM%26hl%3Den-US&followup=https://policies.google.com/terms?gl%3DJM%26hl%3Den-US&hl=en-US&ec=GAZAoQQ>
<https://accounts.google.com/ServiceLogin?passive=1209600&continue=https://policies.google.com/terms?hl%3Den-US&followup=https://policies.google.com/terms?hl%3Den-US&hl=en-US&ec=GAZAoQQ>
+4 more affected URL(s)

2. [HIGH] Cookie 'NID' Missing Secure Flag

1 finding(s), 1 affected URL(s)

Description: The cookie 'NID' does not have the Secure flag set, making it vulnerable to interception over HTTP connections.

Evidence: Cookie 'NID' is missing the Secure flag

Recommendation: Set the Secure flag on all cookies to ensure they are only sent over HTTPS.

Affected URLs:

<https://accounts.google.com/TOS?loc=JM&hl=en-US&privacy=true>

3. [HIGH] Directory Listing Enabled

2 finding(s), 2 affected URL(s)

Description: Directory listing is enabled, exposing file structure and potentially sensitive files.

Evidence: Directory listing detected in response content

Recommendation: Disable directory listing in web server configuration.

Affected URLs:

<https://accounts.google.com/TOS?loc=JM&hl=en-GB&privacy=true>
<https://accounts.google.com/TOS?loc=JM&hl=en-US&privacy=true>

4. [HIGH] Potential XSS Vulnerability in HTML Content

26 finding(s), 26 affected URL(s)

Description: The page contains patterns that may indicate XSS vulnerabilities in dynamic content.

Evidence: HTML contains script-like patterns in content

Recommendation: Implement proper input validation and output encoding.

Affected URLs:

<https://accounts.google.com>
<https://accounts.google.com/?gl=JM&hl=en-GB>
<https://accounts.google.com/?gl=JM&hl=en-US>
<https://accounts.google.com/?hl=en-US>
<https://accounts.google.com/ServiceLogin?hl=en-GB&continue=https://policies.google.com/terms?gl%3DJM%26hl%3Den-GB>
<https://accounts.google.com/ServiceLogin?hl=en-US&continue=https://policies.google.com/terms?gl%3DJM%26hl%3Den-US>
+20 more affected URL(s)

5. [MEDIUM] Dynamic Code Execution in Client JavaScript

1 finding(s), 1 affected URL(s)

Description: JavaScript uses eval, Function, or string-based timers. These APIs increase XSS impact and are especially dangerous when influenced by URL or user data.

Evidence: Line 2: (function(){var G=function(t,Y,d,y,P,L,C,v,O,I,H,m){{l=20;while(l!=44)if(l==69)m=Y,l=95;else if(l==65)=(d-9^23)<d&&(d+7&14)>=d?69:95;else if(l==54)H=function(){},P=void 0,C=Q(Y...

Recommendation: Replace dynamic code execution with explicit function calls or a safe parser for the expected data format.

Affected URLs:

<https://accounts.google.com/b/0/AddMailService#inline-script-1>

6. [MEDIUM] Google or Firebase API Key Exposed in JavaScript

1 finding(s), 1 affected URL(s)

Description: A Google/Firebase-style API key is present in browser-visible JavaScript. Public API keys should be tightly restricted by referrer, API, and quota.

Evidence: Line 1: window.WIZ_global_data = {"AfY8Hf":false,"DpimGf":false,"EP1ykd":["/_/*","/accounts/*"],"FL1an":false,"FdrFJe":"5829073982041647034","FoW6je":false,"HiPsb":1,"Im6cmf":"/_/ident...

Recommendation: Restrict the key in the provider console, move privileged operations server-side, and rotate the key if it was unrestricted.

Affected URLs:

<https://accounts.google.com/TOS?loc=JM&hl=en-US&privacy=true#inline-script-1>

7. [MEDIUM] Security-Sensitive Value Uses Math.random

1 finding(s), 1 affected URL(s)

Description: Math.random appears near generation of a security-sensitive value. It is not cryptographically secure.

Evidence: Line 5: n("globalThis",function(b){return b||h});n("Symbol",function(b){if(b)return b;var c=function(g,k){this.i=g;a(this,"description",{configurable:!0,writable:!0,value:k});c.prototy...

Recommendation: Use crypto.getRandomValues or server-generated random values for tokens, nonces, and secrets.

Affected URLs:

<https://accounts.google.com/b/0/AddMailService#inline-script-6>

8. [MEDIUM] Cookie 'NID' Missing SameSite Attribute

1 finding(s), 1 affected URL(s)

Description: The cookie 'NID' does not have the SameSite attribute set, making it vulnerable to CSRF attacks.

Evidence: Cookie 'NID' is missing SameSite attribute

Recommendation: Set SameSite attribute to Lax or Strict for session cookies.

Affected URLs:

<https://accounts.google.com/TOS?loc=JM&hl=en-US&privacy=true>

9. [MEDIUM] Form Missing CSRF Protection

13 finding(s), 13 affected URL(s)

Description: The form lacks CSRF protection tokens, making it vulnerable to CSRF attacks.

Evidence: No CSRF token found in form or hidden inputs

Recommendation: Implement CSRF tokens for all forms that perform state-changing actions.

Affected URLs:

<https://accounts.google.com>

<https://accounts.google.com/?gl=JM&hl=en-GB>

<https://accounts.google.com/?gl=JM&hl=en-US>

<https://accounts.google.com/?hl=en-US>

<https://accounts.google.com/ServiceLogin?hl=en-GB&continue=https://policies.google.com/terms?gl%3DJM%26hl%3Den-GB>

<https://accounts.google.com/ServiceLogin?hl=en-US&continue=https://policies.google.com/terms?gl%3DJM%26hl%3Den-US>

+7 more affected URL(s)

10. [MEDIUM] Missing Strict-Transport-Security Header

7 finding(s), 7 affected URL(s)

Description: The Strict-Transport-Security header is missing on this page. HSTS enforces HTTPS connections.

Evidence: Header 'Strict-Transport-Security' not found in response headers.

Recommendation: Add HSTS header to enforce HTTPS and prevent SSL stripping.

Affected URLs:

<https://accounts.google.com/TOS?gl=JM&hl=en-GB>
<https://accounts.google.com/TOS?gl=JM&hl=en-US>
<https://accounts.google.com/TOS?hl=en-US>
<https://accounts.google.com/TOS?loc=JM&hl=en-GB>
<https://accounts.google.com/TOS?loc=JM&hl=en-GB&privacy=true>
<https://accounts.google.com/TOS?loc=JM&hl=en-US>
+1 more affected URL(s)

11. [MEDIUM] Missing X-Frame-Options Header

7 finding(s), 7 affected URL(s)

Description: The X-Frame-Options header is missing on this page. X-Frame-Options prevents clickjacking attacks.

Evidence: Header 'X-Frame-Options' not found in response headers.

Recommendation: Set X-Frame-Options to DENY or SAMEORIGIN.

Affected URLs:

<https://accounts.google.com/TOS?gl=JM&hl=en-GB>
<https://accounts.google.com/TOS?gl=JM&hl=en-US>
<https://accounts.google.com/TOS?hl=en-US>
<https://accounts.google.com/TOS?loc=JM&hl=en-GB>
<https://accounts.google.com/TOS?loc=JM&hl=en-GB&privacy=true>
<https://accounts.google.com/TOS?loc=JM&hl=en-US>
+1 more affected URL(s)

12. [MEDIUM] Form Missing CSRF Protection

13 finding(s), 13 affected URL(s)

Description: A form with 8 inputs is missing CSRF protection tokens.

Evidence: Form action: https://accounts.google.com/v3/signin/identifier?continue=https://accounts.google.com/&dsh=S-566498259:1782744862996155&flowEntry=ServiceLogin&flowName=WebLiteSignIn&followup=https://accounts.google.com/&ifkv=AcDsRvyJPqFWof5VSK1KAJDdtvhkz08h47OEekluAXOKNc6D6fdjVaBZ6ySulc9qq8L_p9AdWbHF, Method: POST

Recommendation: Implement CSRF tokens for all state-changing forms.

Affected URLs:

<https://accounts.google.com>
<https://accounts.google.com/?gl=JM&hl=en-GB>
<https://accounts.google.com/?gl=JM&hl=en-US>
<https://accounts.google.com/?hl=en-US>
<https://accounts.google.com/ServiceLogin?hl=en-GB&continue=https://policies.google.com/terms?gl%3DJM%26hl%3Den-GB>
<https://accounts.google.com/ServiceLogin?hl=en-US&continue=https://policies.google.com/terms?gl%3DJM%26hl%3Den-US>
+7 more affected URL(s)

13. [MEDIUM] Form Missing CSRF Protection

6 finding(s), 6 affected URL(s)

Description: A form with 1 inputs is missing CSRF protection tokens.

Evidence: Form action: https://accounts.google.com/signin/username recovery?continue=https://accounts.google.com/&dsh=S-566498259:1782744862996155&flowEntry=ServiceLogin&flowName=WebLiteSignIn&followup=https://accounts.google.com/&ifkv=AcDsRvyJPqFWof5VSK1KAJDdtvhkz08h47OEekluAXOKNc6D6fdjVaBZ6ySulc9qq8L_p9AdWbHF, Method: POST

Recommendation: Implement CSRF tokens for all state-changing forms.

Affected URLs:

https://accounts.google.com/signin/username recovery?continue=https://accounts.google.com/&dsh=S-566498259:1782744862996155&flowEntry=ServiceLogin&flowName=WebLiteSignIn&followup=https://accounts.google.com/&ifkv=AcDsRvyJPqFWof5VSK1KAJDdtvhkz08h47OEekluAXOKNc6D6fdjVaBZ6ySulc9qq8L_p9AdWbHF
https://accounts.google.com/signin/username recovery?continue=https://accounts.google.com/?gl%3DJM%26hl%3Den-US&dsh=S-837164890:1782744865568215&flowEntry=ServiceLogin&flowName=WebLiteSignIn&followup=https://accounts.google.com/?gl%3DJM%26hl%3Den-US&hl=en-US&ifkv=AcDsRvxZ6Y8MR1O8KWN4rxMqt9vB1MZa2s4_kgwwEHWygUmKG5QDliihO1LIOrLCHKul8trBj7Hbg
<https://accounts.google.com/signin/username recovery?continue=https://accounts.google.com/b/0/AddMailService&dsh=S439495089:1782744844136356&flowEntry=ServiceLogin&flowName=WebLiteSignIn&followup=https://accounts.google.com/b/0/AddMailService&ifkv=AcDsRvxPogAKI9eiHVXsbcKEECc1OJB>

ZMA_-zBE7yzqiUco81QvU98e18ty83up9RKN4HvPuWnNh
https://accounts.google.com/signin/username recovery?continue=https://policies.google.com/privacy?gl%3DJM%26hl%3Den-US&dsh=S-718045890:1782744858541977&ec=GAZAoQQ&flowEntry=ServiceLogin&flowName=WebLiteSignIn&followup=https://policies.google.com/privacy?gl%3DJM%26hl%3Den-US&hl=en-US&ifkv=AcDsRvzH24wsCwLqML4mSuFfo3JCblB2Gs2TtyYJv4VBbN1xRZEuBtlBmKw0qbwLyDqAaN98tOpQcA
https://accounts.google.com/signin/username recovery?continue=https://policies.google.com/terms?gl%3DJM%26hl%3Den-US&dsh=S-1373961948:1782744864234645&flowEntry=ServiceLogin&flowName=WebLiteSignIn&hl=en-US&ifkv=AcDsRvzRloz3NoM8u74eQijSRJiepQ2i4Ju9f054kCRE1saSGTw2JUHnuKAHHS3ypoJ6-K3vSJvbJQ
https://accounts.google.com/signin/username recovery?continue=https://policies.google.com/terms?gl%3DJM%26hl%3Den-US&dsh=S487251444:1782744867104548&ec=GAZAoQQ&flowEntry=ServiceLogin&flowName=WebLiteSignIn&followup=https://policies.google.com/terms?gl%3DJM%26hl%3Den-US&hl=en-US&ifkv=AcDsRvyt1XQnzSZrH6BFdj03kSgRhcuHZS7-nXp83X6L7rsLkkmU6ggK5x2t_ZBIVpObGi7wFmC

14. [LOW] JavaScript Source Map Reference Exposed

1 finding(s), 1 affected URL(s)

Description: A production JavaScript file references a source map. Public source maps can expose original source code, comments, route names, and implementation details.

Evidence: Line 1: `//# sourceMappingURL=data:application/json;charset=utf-8;base64,eyJ2ZXJzaW9uLjogMywic291cmNlcyI6WyliXSwic291cmNlc0NvbnRibnQiOlsilCjdlCjUuYW11cyI6WyJjbG9zdXJlRlhuYW1pY0J1dHRvbiJdL...`

Recommendation: Do not publish production source maps unless you intentionally make source code public.

Affected URLs:

https://accounts.google.com/b/0/AddMailService#inline-script-1

15. [LOW] Missing Referrer-Policy Header

32 finding(s), 32 affected URL(s)

Description: The Referrer-Policy header is missing on this page. Controls how much referrer information is sent.

Evidence: Header 'Referrer-Policy' not found in response headers.

Recommendation: Set Referrer-Policy to strict-origin-when-cross-origin or similar.

Affected URLs:

https://accounts.google.com
https://accounts.google.com/?gl=JM&hl=en-GB
https://accounts.google.com/?gl=JM&hl=en-US
https://accounts.google.com/?hl=en-US
https://accounts.google.com/ServiceLogin?hl=en-GB&continue=https://policies.google.com/terms?gl%3DJM%26hl%3Den-GB
https://accounts.google.com/ServiceLogin?hl=en-US&continue=https://policies.google.com/terms?gl%3DJM%26hl%3Den-US
+26 more affected URL(s)

16. [LOW] Missing Permissions-Policy Header

6 finding(s), 6 affected URL(s)

Description: The Permissions-Policy header is missing on this page. Controls which browser features can be used.

Evidence: Header 'Permissions-Policy' not found in response headers.

Recommendation: Set Permissions-Policy to restrict unnecessary features.

Affected URLs:

https://accounts.google.com/signin/username recovery?continue=https://accounts.google.com/&dsh=S-566498259:1782744862996155&flowEntry=ServiceLogin&flowName=WebLiteSignIn&followup=https://accounts.google.com/&ifkv=AcDsRvyJPqFWof5VSK1KAJDdtvhkz08h47OEekluAXOKNc6D6fdjVaBZ6ySUIc9qq8L_p9AdWbHF
https://accounts.google.com/signin/username recovery?continue=https://accounts.google.com/?gl%3DJM%26hl%3Den-US&dsh=S-837164890:1782744865568215&flowEntry=ServiceLogin&flowName=WebLiteSignIn&followup=https://accounts.google.com/?gl%3DJM%26hl%3Den-US&hl=en-US&ifkv=AcDsRvxZ6Y8MR1O8KWN4rxMqt9vB1MZA2s4_kgwwEHWygUmKG5QDliiO1LlOriLCHKul8trBj7Hbg
https://accounts.google.com/signin/username recovery?continue=https://accounts.google.com/b/0/AddMailService&dsh=S439495089:1782744844136356&flowEntry=ServiceLogin&flowName=WebLiteSignIn&followup=https://accounts.google.com/b/0/AddMailService&ifkv=AcDsRvxPogAKI9eiHVXsbckEECc1OJBZMA_-zBE7yzqiUco81QvU98e18ty83up9RKN4HvPuWnNh
https://accounts.google.com/signin/username recovery?continue=https://policies.google.com/privacy?gl%3DJM%26hl%3Den-US&dsh=S-718045890:1782744858541977&ec=GAZAoQQ&flowEntry=ServiceLogin&flowName=WebLiteSignIn&followup=https://policies.google.com/privacy?gl%3DJM%26hl%3Den-US&hl=en-US&ifkv=AcDsRvzH24wsCwLqML4mSuFfo3JCblB2Gs2TtyYJv4VBbN1xRZEuBtlBmKw0qbwLyDqAaN98tOpQcA
https://accounts.google.com/signin/username recovery?continue=https://policies.google.com/terms?gl%3DJM%26hl%3Den-US&dsh=S-1373961948:1782744864234645&flowEntry=ServiceLogin&flowName=WebLiteSignIn&hl=en-US&ifkv=AcDsRvzRloz3NoM8u74eQijSRJiepQ2i4Ju9f054kCRE1saSGTw2JUHnuKAHHS3ypoJ6-K3vSJvbJQ
https://accounts.google.com/signin/username recovery?continue=https://policies.google.com/terms?gl%3DJM%26hl%3Den-US&dsh=S487251444:1782744867104548&ec=GAZAoQQ&flowEntry=ServiceLogin&flowName=WebLiteSignIn&followup=https://policies.google.com/terms?gl%3DJM%26hl%3Den-US&hl=en-US&ifkv=AcDsRvyt1XQnzSZrH6BFdj03kSgRhcuHZS7-nXp83X6L7rsLkkmU6ggK5x2t_ZBIVpObGi7wFmC

